

CloudRuplets : Runbook Réponse à Incident

AWS eu-west-3 (Paris) · 3 VPC isolés (prod/staging/dev) · RGPD · Terraform IaC · v1.0

Contacts incident	Console AWS	Canaux alertes	Niveaux sévérité
Lead sécurité · Astreinte DevOps · DPO (si donnée perso)	eu-west-3 uniquement · MFA obligatoire · jamais root	SNS → email équipe sécu · CloudWatch Alarms	S1 compromission prod · S2 staging/dev ou risque · S3 anomalie à investiguer

Réflexes communs à tout incident (avant d'ouvrir un scénario)

1. Préserver	Snapshot EBS de l'EC2 suspecte avant toute action destructive. Exporter les 24h précédentes de VPC Flow Logs et CloudTrail vers un bucket forensic dédié.
2. Isoler	Détacher l'instance du Security Group applicatif et l'attacher à un SG <i>quarantine</i> (0 inbound/outbound sauf SSM). Ne pas terminer.
3. Tracer	Ouvrir un ticket incident horodaté. Toute commande exécutée est loggée (CloudTrail). Ne pas tenter de contourner.
4. Notifier	SNS déclenche déjà l'alerte. Si donnée personnelle potentiellement exposée : horloge RGPD 72h démarre, notifier le DPO immédiatement.

Scénarios d'incident spécifiques à l'architecture

#1. Compromission EC2 Nginx (public subnet prod)		S1
Signaux	Pic 5xx ou CPU sur Nginx · connexions sortantes inhabituelles dans les VPC Flow Logs (10.0.1.0/24 vers IP externe non-AWS) · alarme CloudWatch sur <i>NetworkOut</i> · entrée CloudTrail GetParameter anormale via le rôle EC2.	
Confinement	(1) Remplacer le SG de l'instance par sg-quarantine-prod. (2) Révoquer le rôle IAM attaché via DisassociateIAMInstanceProfile, ce qui coupe l'accès SSM Parameter Store et S3 instantanément. (3) Snapshot EBS root + data. (4) Ne pas <i>terminate</i> : l'instance reste pour l'analyse mémoire via SSM Session Manager.	
Éradication	Relancer l'AMI durcie via terraform apply (pipeline prod avec approbation manuelle). Le nouveau rôle IAM est créé, l'ancien est supprimé. Ne jamais restaurer depuis un snapshot postérieur à la compromission.	
Rotation	Rotation obligatoire dans SSM Parameter Store de tous les secrets que le rôle pouvait lire (credentials RDS prod, clés d'API tierces). Rotation KMS CMK prod-key si exfiltration confirmée.	
Post-mortem	Vérifier IMDSv2 bien <i>enforced</i> (HttpTokens=required). Reconfirmer que le SG public n'ouvre que 80/443. Ajouter alarme CloudWatch sur volume sortant EC2 publique si pas déjà en place.	

#2. Fuite de secret Git / bypass Gitleaks		S1
Signaux	Alerte GitHub Secret Scanning · commit où Gitleaks aurait dû bloquer mais le hook pre-commit a été bypassé (--no-verify) · ou secret en clair dans un terraform.tfvars poussé par erreur.	
Confinement	Considérer le secret comme compromis dès publication, même privé. Révoquer immédiatement dans AWS (clé IAM, token API) ou côté fournisseur tiers. <i>Purger l'historique Git ne suffit pas.</i>	
Éradication	Remplacer la valeur dans SSM Parameter Store (jamais en dur dans le code). Relancer le déploiement : l'EC2 app lit SSM au boot. Forcer redémarrage du service applicatif pour recharger les paramètres.	
Détection rétro	Requête CloudTrail sur les 30 derniers jours : userIdentity.accessKeyId = clé compromise, noter toute action inhabituelle (région hors eu-west-3, appels ListBuckets, GetSecretValue).	
Correctif pipeline	Rendre Gitleaks bloquant côté GitHub Action (pas seulement pre-commit local). Activer les <i>required status checks</i> sur main pour que Gitleaks/Checkov/Trivy soient obligatoires avant merge.	

#3. SQLi / accès RDS anormal depuis l'app tier		S1
Signaux	Logs RDS PostgreSQL : erreurs de syntaxe en masse, requêtes avec UNION SELECT ou pg_sleep · pic de connexions depuis l'EC2 app · VPC Flow Logs montrant trafic 5432 soutenu entre 10.0.2.0/24 et 10.0.3.0/24.	
Confinement	Si attaque via vulnérabilité applicative : passer le SG app en mode maintenance (page statique depuis Nginx). Le SG-DB n'accepte déjà que le SG-APP en source, pas d'accès direct Internet possible : ne pas toucher à cette règle.	
Évaluation fuite	Activer/augmenter log_statement=all temporairement. Extraire requêtes sur 72h → identifier si des SELECT ont réussi à sortir des données. Si oui : horloge RGPD 72h , notifier DPO, préparer registre incident.	
Éradication	Patcher l'applicatif (paramètres bindés, ORM), redéployer via pipeline avec approbation prod. Rotation des credentials RDS dans SSM. Restaurer depuis backup automatique (rétention 7j) uniquement si intégrité données altérée.	
Renforcement	Ajouter tests d'injection dans la CI (OWASP ZAP baseline). Alarme CloudWatch sur DatabaseConnections RDS > seuil nominal +50 %.	

#4. S3 exposé publiquement / drift Terraform		S1
Signaux	Checkov devait bloquer en CI mais un terraform apply manuel a été fait. Alerte IAM Access Analyzer : bucket S3 prod avec ACL ou policy rendant un préfixe lisible publiquement. Pic GetObject anonymes dans CloudTrail.	
Confinement immédiat	aws s3api put-public-access-block sur le bucket avec les 4 flags à true. Supprimer la policy incriminée. Vérifier que <i>Block Public Access</i> au niveau du compte est ON.	
Évaluation	Lister via CloudTrail les GetObject sur la période d'exposition, filtrer sourceIPAddress externes. Si objets contenant données perso téléchargés → procédure RGPD 72h.	
Éradication	Reconvergence Terraform : terraform plan doit maintenant être clean. Supprimer la possibilité d'apply manuel hors pipeline (désactiver les clés IAM humaines, forcer le passage par OIDC GitHub Actions).	
Renforcement	Rendre Checkov bloquant sur les règles S3 public (CKV_AWS_53 à 57). Activer S3 Object Lock sur les buckets contenant des données réglementaires.	

#5. Compromission pipeline CI/CD (OIDC / state Terraform)		S1
Signaux	Workflow GitHub modifié sans PR · push direct sur main contournant les <i>branch protections</i> · CloudTrail : AssumeRoleWithWebIdentity depuis un repo ou une branche non attendue · Terraform state modifié hors heures ouvrées.	
Confinement	Désactiver le rôle IAM assumable par OIDC (aws iam update-assume-role-policy avec condition impossible). Verrouiller la branche main. Révoquer les tokens GitHub personnels suspects. Bloquer le lock DynamoDB du state Terraform.	
Évaluation	Relire tous les terraform apply CloudTrail sur 30j : chaque changement IAM, SG, route table est suspect. Vérifier l'intégrité du state S3 via versioning (restaurer version antérieure connue si besoin).	
Éradication	Réémettre le rôle OIDC avec condition token.actions.githubusercontent.com:sub stricte sur repo et branche et environnement. Audit complet des <i>self-hosted runners</i> éventuels.	
Renforcement	Exiger <i>Required reviewers</i> sur l'environnement GitHub prod. Signed commits obligatoires. Plan Terraform en PR obligatoire avec diff visible avant apply.	

#6. DDoS L7 / abus d'API sur CloudFront → Nginx		S2
Signaux	CloudFront : hausse brutale des requêtes · CloudWatch : CPU Nginx saturé, 5xx en hausse · VPC Flow Logs : nombreuses IP sources vers 10.0.1.0/24. Shield Standard absorbe L3/L4 mais pas L7.	
Confinement	Activer rate-limiting Nginx (limit_req_zone) si pas déjà en place. Côté CloudFront : activer une <i>response headers policy</i> + envisager règles WAF managées (AWSManagedRulesCommonRuleSet). Cela sort du strict Free Tier mais reste payable à la demande.	
Résilience	Scaler temporairement l'EC2 Nginx (t3.small) le temps de l'attaque. RDS Multi-AZ protège la couche données. Staging et dev ne sont pas des cibles valides à protéger en priorité.	
Post-mortem	Décider si WAF managé devient permanent (arbitrage coût / exposition). Documenter l'IP ou l'ASN source pour réutilisation future dans une <i>IP set</i> WAF.	

#7. Copie de données prod vers dev (violation RGPD)		S2
Signaux	CloudTrail : CreateDBSnapshot sur RDS prod suivi d'un RestoreDBInstanceFromDBSnapshot dans le VPC dev (10.2.0.0/16). Ou CopyObject entre bucket S3 prod et bucket dev.	
Confinement	Supprimer immédiatement la RDS dev restaurée et son snapshot dérivé. Purger le bucket S3 dev des objets copiés. Horloge RGPD 72h : même en interne, c'est un traitement non autorisé de données personnelles.	
Éradication	Révoquer les permissions de l'identité IAM ayant effectué l'action. Vérifier qu'aucun pipeline automatisé n'autorise cette copie (SCPs au niveau organisation si applicable).	
Renforcement	Mettre en place un script d'anonymisation validé pour alimenter dev/staging. Policy IAM explicite : Deny sur rds:RestoreDBInstance* ciblant un VPC autre que celui d'origine du snapshot.	

Sources de vérité pendant un incident : CloudTrail (tous API calls, S3 chiffré KMS) · VPC Flow Logs (S3 + CloudWatch) · RDS logs PostgreSQL · Nginx access/error logs · GitHub Actions run logs.

RGPD Art.33-34 : toute suspicion d'accès non autorisé à des données personnelles déclenche l'horloge de 72h pour notification à la CNIL. Le DPO décide. Ne pas attendre confirmation technique complète.